QPFL – Quobly-AXA challenge

Alice Busi, Clara Hamousz, Giovanni Bragadin, Timothé Jobin

March 1, 2026

Chapter 1

Introduction

Ransomware has become one of the most financially damaging and operationally disruptive forms of cyber risk faced by modern enterprises. Technology consulting firms are particularly exposed: they operate complex IT infrastructures, rely heavily on cloud services, enable remote access environments, and often manage sensitive data for multiple clients. A single ransomware incident can therefore trigger not only direct recovery and downtime costs, but also reputational damage, contractual penalties, and cascading losses across connected organizations.

For insurers, this creates a fundamentally complex underwriting problem. Cyber risk is dynamic, technology-dependent, and strongly influenced by the security posture of the insured firm. Unlike traditional insurance lines, past claims data alone is insufficient for pricing. The insurer must assess forward-looking risk drivers such as infrastructure exposure, control effectiveness, and organizational behavior, while simultaneously accounting for competitive market pressure and customer price sensitivity.

This leads to a joint optimization challenge.

An insurer offering ransomware coverage must decide:

1. Which cybersecurity controls to require from the insured (risk mitigation / underwriting decision).
2. What premium to charge (pricing decision).
3. How to structure policy terms such as deductible and coverage limit (contract design).

These decisions are interdependent.

Requiring more security controls reduces expected loss but increases friction for the client, potentially lowering the probability that the policy is accepted. Increasing the premium improves margin per policy but reduces demand. Lowering the deductible makes the contract more attractive but increases expected payout and capital exposure. The optimal insurance offer must balance all these forces simultaneously.

Our project addresses this problem by building a unified mathematical framework that integrates:

- A structural ransomware frequency model,
- A severity model capturing recovery, downtime, and reputational losses,
- An insurance payout mechanism with deductible and limit,
- A demand model that reflects competitive pricing and underwriting burden.

Rather than treating pricing and risk assessment separately, we combine them into a single objective: maximize the insurer's expected profit under realistic operational constraints. This transforms cyber underwriting into a structured optimization problem.

The resulting model captures the economic trade-offs between risk mitigation, profitability, and customer acceptance in a transparent and computationally tractable way. By reformulating the nonlinear components into a quadratic structure, the problem becomes suitable for advanced optimization techniques, including combinatorial and quantum-inspired approaches.

In the context of a rapidly evolving cyber insurance market—characterized by pricing volatility, increasing underwriting scrutiny, and systemic risk exposure—an optimization-based framework provides a principled way to move from heuristic pricing toward rigorous, data-driven decision-making.

Our goal in this hackathon is to demonstrate that ransomware risk assessment and insurance pricing can be unified into a single optimization model capable of supporting more resilient and economically sound cyber insurance strategies.

Chapter 2

Model

Joint Loss Function for Ransomware Risk Assessment and Pricing (AXA Cyber Insurance)

2.1 Goal and Modeling Philosophy

We consider a single insured technology consulting company exposed to ransomware. AXA must jointly decide:

- which cybersecurity controls to require (underwriting / risk mitigation),
- what premium to offer (pricing),
- and optionally other policy terms (deductible and limit).

We define a single *joint loss function* that combines:

1. ransomware risk assessment (frequency and impact / severity),
2. insurer payout mechanics (deductible/limit),
3. customer acceptance probability (demand) depending on price and underwriting friction,
4. expenses and risk/capital loading.

The optimization problem is to choose decisions that minimize this joint loss.

1. What Is the Dataset Supposed to Represent?

In this setting, we are modeling:

- One insured company,
- A finite set of possible security controls.

Therefore, the dataset should contain:

A) Company Features (Inputs)

These come from the firm and represent observable characteristics:

$$Rev, \quad N, \quad C, \quad R, \quad As, \quad I, \quad g, \quad p_{comp}$$

These are true data-like inputs describing the insured company.

B) Per-Control Parameters

For each control $i \in V$:

$$\kappa_i \quad \text{(control cost)}$$
$$\alpha_i \quad \text{(frequency reduction)}$$
$$\beta_i \quad \text{(severity reduction)}$$
$$f_i \quad \text{(client friction)}$$

These belong in the dataset because they differ across controls and define the combinatorial structure of the problem.

2. What Should NOT Be in the Dataset

The following are **global structural parameters**. They define the economic and mathematical structure of the model and should be fixed.

- Security posture parameters:
$$z_0, \quad w_i, \quad w_{ij}$$
- Baseline intensity parameter:
$$\lambda_0$$
- Severity scaling parameters:
$$c_1, \quad d_0, \quad d_1, \quad \gamma$$
- Acceptance model parameters:
$$\eta_0, \quad \eta_p, \quad \eta_c$$
- coefficients of baseline ransomware intensity:
$$\lambda_i$$

These parameters should remain constant across optimization runs to ensure:

- numerical stability,
- interpretability,
- tractable optimization within hackathon constraints.

These parameters define the structural behavior of the model and should remain fixed across optimization runs to ensure numerical stability and interpretability.

2.2 Indices, Sets, and Decision Variables

2.2.1 Control set and interactions

- $V = \{1, \ldots, n\}$: set of cybersecurity controls (security protocols).
- $E \subseteq \{\{i, j\} : i, j \in V, i < j\}$: set of interacting control pairs (dependencies between / redundancies).

2.2.2 Decision variables

- $x_i \in \{0, 1\}$ for $i \in V$: binary indicator that control i is required/implemented ($x_i = 1$) or not ($x_i = 0$).
- $p \in \mathbb{R}_+$: premium (annual, in €).

2.2.3 Optional decision variables (policy terms)

To keep the model complete and insurance-realistic, we optionally include:

- $d \in \mathbb{R}_+$: deductible = the initial amount of the loss that the insured company must pay out of its own pocket before the insurance coverage kicks in .
- $u \in \mathbb{R}_+$: policy limit = maximum payout the insurer will provide for a single claim or over a specific period.
- $k \in (0, 1]$: coinsurance factor (insurer pays fraction k of covered loss layer; often $k = 1$).

Decision bundle:

$$\theta = (x, p), \quad \text{where } x = (x_1, \ldots, x_n).$$

2.3 Company (Insured) Feature Variables (Inputs)

These variables describe the insured company. They are *inputs* (observed features), not decision variables.

- `revenue` $\equiv \mathrm{Rev} \in \mathbb{R}_+$: annual revenue (in €).
- `num_employees` $\equiv N \in \mathbb{N}$: number of employees.
- `cloud_dependency` $\equiv C \in [0, 1]$: fraction of infrastructure in cloud.
- `remote_work_ratio` $\equiv R \in [0, 1]$: fraction of employees working remotely.
- `attack_surface_score` $\equiv A_s \in [0, 100]$: external exposure/attack surface score.
- `past_incidents` $\equiv I \in \mathbb{N}_0$: number of cyber incidents in recent history (e.g., past 5 years).
- `industry_risk_factor` $\equiv g \in \mathbb{R}_+$: industry baseline risk multiplier (sector effect).

Derived exposure proxies (implementation-ready). Many ransomware models use proxies such as *assets* and *exposure index*. We derive them from features:

- $\hat{A}$: effective number of IT assets/endpoints (proxy).
- $\hat{E}$: effective exposure index (proxy).

A simple deterministic mapping (choose constants to calibrate synthetic data):

$$\hat{A} = a_0 + a_1 N, \quad a_0 \geq 0,\ a_1 > 0, \tag{2.1}$$

$$\hat{E} = e_0 + e_1 \frac{A_s}{100} + e_2 C + e_3 R + e_4 \min\{I, I_{\max}\}, \tag{2.2}$$

with $e_0 \geq 0$ and $e_1, e_2, e_3, e_4 \geq 0$. We choose the a_i, e_i

Also define daily revenue:

$$\mathrm{Rev}_{\mathrm{daily}} = \frac{\mathrm{Rev}}{365}.$$

2.4 Security Controls: Variables and Per-Control Parameters

For each control $i \in V$, we define the following parameters (these correspond exactly to your dataset fields):

- $\texttt{control_cost}_i \equiv \kappa_i \in \mathbb{R}_+$: implementation/verification cost or friction cost (in € or in normalized "underwriting effort units").
- $\texttt{frequency_reduction}_i \equiv \alpha_i \in [0, 1]$: proportional reduction in ransomware *frequency/intensity* when control i is implemented.
- $\texttt{severity_reduction}_i \equiv \beta_i \in [0, 1]$: proportional reduction in ransomware *severity/impact* when control i is implemented.

Control interactions (optional but recommended). For each interaction pair $\{i, j\} \in E$, define:

$$\alpha_{ij} \in \mathbb{R}, \quad \beta_{ij} \in \mathbb{R}$$

which represent additional (synergistic or redundant) frequency/severity effects when *both* controls are present. Positive values represent synergy; negative values represent redundancy.

2.5 Pricing Variables (Inputs and Decisions)

- $\texttt{premium} \equiv p \in \mathbb{R}_+$: AXA's offered premium (decision variable).
- $\texttt{competitor_price} \equiv p_{\text{comp}} \in \mathbb{R}_+$: competitor benchmark premium for a comparable policy (input).

Define the premium difference:

$$\Delta p = p - p_{\text{comp}}.$$

2.6 Ransomware Risk Assessment Model: Frequency and Severity

We construct an implementation-ready model with many variables while staying coherent.

2.6.1 Security score from controls

Define a *latent security posture*:

$$z(x) = z_0 + \sum_{i \in V} w_i x_i + \sum_{\{i,j\} \in E} w_{ij} x_i x_j,$$

where:

- $z_0 \in \mathbb{R}$ is the baseline security posture $z_0 < 1$,
- $w_i \in \mathbb{R}$ is the marginal effect of control i on posture,
- $w_{ij} \in \mathbb{R}$ is synergy/redundancy on posture.

Map to a bounded security score:

$$S(x) = \sigma(z(x)) = \frac{1}{1 + \exp(-z(x))} \in (0, 1).$$

2.6.2 Frequency / probability of ransomware

We define a base intensity parameter $\lambda_0 > 0$. The intensity depends on the company's sector and its specific infrastructure setup:

$$\lambda(Z) = \lambda_0 \cdot g \cdot (1 + \lambda_C C) \cdot (1 + \lambda_R R).$$

Controls reduce frequency through multiplicative reductions:

$$\Phi_{\text{freq}}(x) = \prod_{i \in V} (1 - \alpha_i)^{x_i} \cdot \prod_{\{i,j\} \in E} (1 - \alpha_{ij})^{x_i x_j}.$$

Define effective intensity $\lambda_{\text{eff}}(x, Z) = \lambda(Z) \cdot \Phi_{\text{freq}}(x)$. We model the occurrence probability using the effective asset count $\hat{A}$ and exposure index $\hat{E}$ to scale the risk to the company size:

$$\Pr_{\text{ran}}(x, Z) = 1 - \exp\Big(-\lambda_{\text{eff}}(x, Z) \cdot \hat{A} \cdot \hat{E} \cdot [1 - S(x)]\Big).$$

2.6.3 Severity / impact of ransomware

We define a baseline impact function based on recovery cost, downtime business interruption, and legal/reputation loss.

Parameters:

- $c_1 > 0$: recovery cost per asset.
- $d_0 \geq 0$: baseline downtime (days).
- $d_1 \geq 0$: downtime sensitivity to assets and weak security.
- $\gamma \geq 0$: proportional legal+reputation cost as fraction of annual revenue.

Recovery:

$$\text{Recovery}(Z) = c_1 \hat{A}.$$

Downtime:

$$\text{Downtime}(x, Z) = d_0 + d_1 \hat{A}(1 - S(x)).$$

Business interruption:

$$\text{BI}(x, Z) = \text{Rev}_{\text{daily}} \cdot \text{Downtime}(x, Z).$$

Legal and reputation:

$$\text{Legal} + \text{Reputation} = \gamma \text{Rev}.$$

Baseline impact:

$$\text{Impact}_0(x, Z) = \text{Recovery}(Z) + \text{BI}(x, Z) + \gamma \text{Rev}.$$

Controls reduce severity through multiplicative reductions:

$$\Phi_{\text{sev}}(x) = \prod_{i \in V} (1 - \beta_i)^{x_i} \cdot \prod_{\{i,j\} \in E} (1 - \beta_{ij})^{x_i x_j}.$$

Effective impact:

$$\text{Impact}(x, Z) = \text{Impact}_0(x, Z) \cdot \Phi_{\text{sev}}(x).$$

2.6.4 Raw expected annual loss (insured economic loss)

Define the raw expected annual ransomware loss (for the insured):

$$L_{\text{raw}}(x, Z) = \Pr_{\text{ran}}(x, Z) \cdot \text{Impact}(x, Z).$$

2.7 Insurance Payout Model (Deductible, Limit, Coinsurance)

Define the payout function for a realized loss amount $y \geq 0$ with d = 10000, u = 1000000 and k = 1:

$$\text{Pay}(y; d, u, k) = k \cdot \min\Big(\max(y - d, 0), u\Big).$$

Using the deterministic impact proxy $y = \text{Impact}(x, Z)$, define expected insurer payout:

$$\mathbb{E}[\text{Payout}(\theta, Z)] = \Pr_{\text{ran}}(x, Z) \cdot \text{Pay}\big(\text{Impact}(x, Z); d, u, 1\big).$$

2.8 Underwriting Friction and Control Cost

Define AXA's internal or underwriting "cost" of requiring controls:

$$C_{\text{ctrl}}(x) = \sum_{i \in V} \kappa_i x_i,$$

where $\kappa_i = \texttt{control_cost}_i$.

Define customer friction (burden) score:

$$F(x) = \sum_{i \in V} f_i x_i,$$

where $f_i \geq 0$ measures how burdensome control i is for the client (implementation effort, operational disruption, audit burden).

2.9 Acceptance Probability Model (Demand) with Competitor Price

We define acceptance probability $A(\theta, Z) \in (0, 1)$ as a logistic function of:

- premium difference $\Delta p = p - p_{\text{comp}}$,
- underwriting friction $F(x)$,
- policy terms (limit and deductible),
- and optionally company features (e.g., larger firms may be less price-sensitive).

Parameters:

- $\eta_0 \in \mathbb{R}$: baseline intercept.
- $\eta_p > 0$: sensitivity to premium difference (higher premium than competitor reduces acceptance).
- $\eta_c > 0$: sensitivity to friction.

- $\eta_u \geq 0$: sensitivity to limit (higher limit may increase acceptance).
- $\eta_d \geq 0$: sensitivity to deductible (higher deductible may reduce acceptance; sign can be calibrated).

Acceptance probability:

$$A(\theta, Z) = \frac{1}{1 + \exp\Big(-\big[\eta_0 - \eta_p\,(p - p_{\text{comp}}) - \eta_c\,F(x) + \eta_u\,u - \eta_d\,d\big]\Big)}$$

2.10 Expected Profit and the Joint Loss to Minimize

The insurer's objective is to maximize the expected profit from the policy, considering that the premium is only collected if the customer accepts the offer.

2.10.1 Expected Profit

In this simplified implementation, we assume zero administrative expenses and no capital loading. The expected profit is the product of the acceptance probability and the expected net gain (Premium minus Control Verification and Expected Payout):

$$\mathbb{E}[\text{Profit}(\theta, Z)] = A(\theta, Z)\,[p - C_{\text{ctrl}}(x) - \mathbb{E}[\text{Payout}(\theta, Z)]]\,.$$

2.10.2 Joint objective: loss function

The joint loss function $\mathcal{J}$ is the negative of the expected profit. Minimizing this function is equivalent to maximizing AXA's expected profit. We include a penalty term $\mathcal{P}(\theta)$ to handle constraints such as budgets or control dependencies:

$$\boxed{\mathcal{J}(\theta, Z) = -\mathbb{E}[\text{Profit}(\theta, Z)] + \mathcal{P}(\theta)}$$

2.11 Penalty Terms for Constraints ($\mathcal{P}(\theta)$)

The penalty function $\mathcal{P}(\theta)$ transforms hard operational and financial constraints into numerical costs. This ensures that the optimization algorithm avoids decision bundles that are technically impossible or financially non-viable for the client.

2.11.1 Budgetary Constraint Penalty

We assume the insured company has a maximum annual cybersecurity budget B. If the total cost of required controls exceeds this threshold, a quadratic penalty is applied:

$$\mathcal{P}_B(\theta) = \mu_B \left(\max \left(\sum_{i \in V} \kappa_i x_i - B, 0 \right) \right)^2$$

where μ_B is a high-magnitude penalty weight. The quadratic form ensures that larger budget violations result in disproportionately higher joint losses.

2.11.2 Control Dependency Penalty

Certain cybersecurity controls are technically contingent upon others (e.g., *Automated Patching* may require *Centralized Asset Inventory*). For a set of rules R where control i requires control j:

$$\mathcal{P}_{\text{dep}}(\theta) = \sum_{(i,j)\in R} \mu_{\text{dep}} \cdot x_i(1 - x_j)$$

This term is non-zero (equal to μ_{dep}) only if the dependent control is required ($x_i = 1$) while the prerequisite is omitted ($x_j = 0$).

2.11.3 Total Penalty Construction

The aggregate penalty is the sum of all individual constraint components:

$$\mathcal{P}(\theta) = \mathcal{P}_B(\theta) + \mathcal{P}_{\text{dep}}(\theta)$$

2.12 Full Implementation Recipe

Given company features $(\text{Rev}, N, C, R, A_s, I, g)$, competitor price p_{comp}, and parameters:

1. Compute proxies $\hat{A}$ and $\hat{E}$ from N, C, R, A_s, I.
2. Compute security posture $z(x)$ and security score $S(x) = \sigma(z(x))$.
3. Compute feature-based intensity $\lambda(Z)$ and control-based reduction $\Phi_{\text{freq}}(x)$.
4. Compute ransomware probability:
$$\Pr_{\text{ran}}(x, Z) = 1 - \exp\big(-\lambda(Z)\Phi_{\text{freq}}(x)\,\hat{A}\hat{E}[1 - S(x)]\big).$$
5. Compute baseline impact $\text{Impact}_0(x, Z)$ and severity reduction $\Phi_{\text{sev}}(x)$.
6. Compute effective impact:
$$\text{Impact}(x, Z) = \text{Impact}_0(x, Z)\Phi_{\text{sev}}(x).$$
7. Compute expected payout:
$$\mathbb{E}[\text{Payout}(\theta, Z)] = \Pr_{\text{ran}}(x, Z) \cdot k \cdot \min(\max(\text{Impact}(x, Z) - d, 0), u).$$
8. Compute control cost $C_{\text{ctrl}}(x) = \sum_i \kappa_i x_i$ and friction $F(x) = \sum_i f_i x_i$.
9. Compute acceptance probability:
$$A(\theta, Z) = \frac{1}{1 + \exp(-[\eta_0 - \eta_p(Z)(p - p_{\text{comp}}) - \eta_c F(x) + \eta_u u - \eta_d d])}.$$
10. Compute expected profit:
$$\mathbb{E}[\text{Profit}(\theta, Z)] = A(\theta, Z)\left[p - C_{\text{ctrl}}(x) - \mathbb{E}[\text{Payout}(\theta, Z)]\right].$$
11. Compute total joint loss:
$$\mathcal{J}(\theta, Z) = -\mathbb{E}[\text{Profit}(\theta, Z)] + \mathcal{P}(\theta).$$

2.13 Optimization Problem

The final optimization problem is:

$$\boxed{\min_{\theta=(x,p)} \quad \mathcal{J}(\theta, Z) \quad \text{s.t.} \quad x_i \in \{0,1\},\ p \geq 0.}$$

Dataset alignment. A synthetic dataset can store:

- company features: $\text{Rev}, N, C, R, A_s, I, g$ and competitor price p_{comp},
- per-control parameters: κ_i (`control_cost`), α_i (`frequency_reduction`), β_i (`severity_reduction`),
- optional pairwise interaction parameters: α_{ij}, β_{ij},
- global parameters: $\lambda_0, c_1, d_0, d_1, \gamma$, and acceptance parameters η..

Full Linearization of the Ransomware Optimization Model

We linearize the original nonlinear model step by step, keeping terms up to second order in the binary control variables x_i and later in the premium p.

Throughout, $x_i \in \{0,1\}$.

2.14 Linearization of the Ransomware Probability

Original definition:

$$Pr_{ran}(x, Z) = 1 - \exp\Big(-\lambda(Z)\,\Phi_{freq}(x)\,\hat{A}\,\hat{E}\,[1 - S(x)]\Big)$$

1.1 Small-Risk Approximation

Assume small intensity:

$$1 - e^{-\Theta} \approx \Theta$$

Define:

$$\Lambda = \lambda(Z)\,\hat{A}\,\hat{E}$$

with

$$\lambda(Z) = \lambda_0 g(1 + \lambda_C C)(1 + \lambda_R R)$$

$$\hat{A} = a_0 + a_1 N$$

$$\hat{E} = e_0 + e_1 \frac{As}{100} + e_2 C + e_3 R + e_4 \min(I, I_{max})$$

Then:

$$Pr_{ran}(x) = \Lambda\,\Phi_{freq}(x)\,(1 - S(x))$$

Legend for Λ:

- λ_0: baseline ransomware intensity
- g: sector multiplier
- λ_C, λ_R: cyber and regulatory loadings
- C, R: cyber maturity and regulation index
- a_0, a_1: asset scaling parameters
- N: firm size
- e_k: exposure scaling coefficients
- As, I: attack surface and infrastructure indicators

2.15 Frequency Reduction Linearization

Original:

$$\Phi_{freq}(x) = \prod_i (1-\alpha_i)^{x_i} \prod_{i<j} (1-\alpha_{ij})^{x_i x_j}$$

First-order approximation:

$$\Phi_{freq}(x) = 1 - \sum_i \alpha_i x_i - \sum_{i<j} \alpha_{ij} x_i x_j$$

Legend:

- α_i: individual control frequency reduction
- α_{ij}: interaction reduction between controls

2.16 Security Score Linearization

Original:

$$S(x) = \sigma(z(x)) = \frac{1}{1+e^{-z(x)}}$$

with

$$z(x) = z_0 + \sum_i w_i x_i + \sum_{i<j} w_{ij} x_i x_j$$

Define:

$$S_0 = \frac{1}{1+e^{-z_0}}, \quad S_0(1-S_0) = \frac{e^{-z_0}}{(1+e^{-z_0})^2}$$

First-order Taylor expansion:

$$S(x) \approx S_0 + S_0(1-S_0)\left(\sum_i w_i x_i + \sum_{i<j} w_{ij} x_i x_j\right)$$

Define:

$$s_i = S_0(1-S_0) w_i$$

$$s_{ij} = S_0(1 - S_0)w_{ij}$$

Thus:

$$1 - S(x) = (1 - S_0) - \sum_i s_i x_i - \sum_{i<j} s_{ij} x_i x_j$$

Legend:

- w_i, w_{ij}: control effects on posture score
- z_0: baseline posture
- s_i, s_{ij}: posture impact coefficients after sigmoid linearization

2.17 Multiplication of Frequency and Vulnerability

We multiply:

$$\Phi_{freq}(x)\,(1 - S(x))$$

Keeping only terms up to second order:

$$= c_0 + \sum_i L_i x_i + \sum_{i<j} Q_{ij} x_i x_j$$

where:

$$c_0 = 1 - S_0$$

$$L_i = -(1 - S_0)\alpha_i - S_0(1 - S_0)w_i(1 - \alpha_i)$$

$$Q_{ij} = -S_0(1 - S_0)w_{ij} - (1 - S_0)\alpha_{ij} + \alpha_i S_0(1 - S_0)w_j + \alpha_j S_0(1 - S_0)w_i$$

Thus:

$$Pr_{ran}(x) = \Lambda\left[c_0 + \sum_i L_i x_i + \sum_{i<j} Q_{ij} x_i x_j\right]$$

2.18 Impact Linearization

Original:

$$Impact(x, Z) = Impact_0(x, Z)\,\Phi_{sev}(x)$$

5.1 Baseline Impact

$$Impact_0(x, Z) = c_1(a_0 + a_1 N) + \frac{Rev}{365}\left[d_0 + d_1(a_0 + a_1 N)(1 - S(x))\right] + \gamma Rev$$

After substitution:

$$Impact_0(x) = I_0 + \sum_i I_i^{(raw)} x_i + \sum_{i<j} I_{ij}^{(raw)} x_i x_j$$

where:

$$I_0 = c_1(a_0 + a_1 N) + \frac{Rev}{365}\left[d_0 + d_1(a_0 + a_1 N)(1 - S_0)\right] + \gamma Rev$$

$$I_i^{(raw)} = -\frac{Rev}{365} d_1(a_0 + a_1 N) s_i$$

$$I_{ij}^{(raw)} = -\frac{Rev}{365} d_1(a_0 + a_1 N) s_{ij}$$

Legend:

- c_1: recovery cost per asset
- d_0, d_1: downtime parameters
- γ: reputational multiplier

5.2 Severity Reduction

$$\Phi_{sev}(x) = 1 - \sum_i \beta_i x_i - \sum_{i<j} \beta_{ij} x_i x_j$$

After multiplication (second order truncation):

$$Impact(x) = I_0 + \sum_i I_i x_i + \sum_{i<j} I_{ij} x_i x_j$$

where:

$$I_i = I_i^{(raw)} - I_0 \beta_i + I_i^{(raw)} \beta_i$$

$$I_{ij} = I_{ij}^{(raw)} - I_0 \beta_{ij} + I_i^{(raw)} \beta_j + I_j^{(raw)} \beta_i$$

Legend:

- β_i, β_{ij}: severity reduction coefficients

2.19 Expected Payout under Internal Regime

6.1 Internal Regime Assumption

Assume that in the relevant optimization region:

$$d < Impact(x) < d + u$$

Then the payout function becomes locally linear:

$$Pay(Impact(x)) = Impact(x) - d$$

Therefore,

$$E[Payout](x) = Pr_{ran}(x)\,(Impact(x) - d)$$

6.2 Quadratic Forms of Probability and Impact

Recall:

$$Pr_{ran}(x) = P_0 + \sum_i P_i x_i + \sum_{i<j} P_{ij} x_i x_j$$

$$Impact(x) = I_0 + \sum_i I_i x_i + \sum_{i<j} I_{ij} x_i x_j$$

Define the deductible-adjusted constant:

$$\tilde{I}_0 = I_0 - d$$

Then:

$$Impact(x) - d = \tilde{I}_0 + \sum_i I_i x_i + \sum_{i<j} I_{ij} x_i x_j$$

6.3 Full Multiplication

$$E[Payout](x) = \left(P_0 + \sum_i P_i x_i + \sum_{i<j} P_{ij} x_i x_j\right)\left(\tilde{I}_0 + \sum_k I_k x_k + \sum_{k<\ell} I_{k\ell} x_k x_\ell\right)$$

We expand and retain terms up to second order in x.

6.4 Constant Term

$$E_0 = P_0 \tilde{I}_0$$

6.5 Linear Terms

Linear contributions arise from:

$$P_0 \sum_i I_i x_i$$

$$\tilde{I}_0 \sum_i P_i x_i$$

$$\left(\sum_i P_i x_i\right)\left(\sum_k I_k x_k\right)$$

Since $x_i^2 = x_i$, the diagonal part contributes to the linear term.
Thus for each i:

$$E_i = P_0 I_i + \tilde{I}_0 P_i + P_i I_i$$

6.6 Quadratic Terms

Quadratic contributions arise from:

$$P_0 \sum_{i<j} I_{ij} x_i x_j$$

$$\tilde{I}_0 \sum_{i<j} P_{ij} x_i x_j$$

and the off-diagonal part of:

$$\left(\sum_i P_i x_i\right)\left(\sum_j I_j x_j\right)$$

For $i < j$:

$$P_i I_j + P_j I_i$$

Thus:

$$E_{ij} = P_0 I_{ij} + \tilde{I}_0 P_{ij} + P_i I_j + P_j I_i$$

6.7 Final Quadratic Representation

$$E[Payout](x) = E_0 + \sum_i E_i x_i + \sum_{i<j} E_{ij} x_i x_j$$

where:

$$E_0 = P_0(I_0 - d)$$

$$E_i = P_0 I_i + (I_0 - d)P_i + P_i I_i$$

$$E_{ij} = P_0 I_{ij} + (I_0 - d)P_{ij} + P_i I_j + P_j I_i$$

2.20 Linearization of the Acceptance Function

7.1 Original Acceptance Model

$$A(\theta, Z) = \frac{1}{1 + \exp(-L)}$$

where

$$L = \eta_0 - \eta_p(Z)(p - p_{comp}) - \eta_c \sum_i f_i x_i + \eta_u u - \eta_d d$$

7.2 Rewrite the Linear Index

Expand the price term:

$$L = \eta_0 + \eta_p(Z)p_{comp} + \eta_u u - \eta_d d - \eta_p p - \eta_c \sum_i f_i x_i$$

Define

$$\tilde{\eta}_0 = \eta_0 + \eta_p(Z)p_{comp} + \eta_u u - \eta_d d$$

Thus

$$L = \tilde{\eta}_0 - \eta_p(Z)p - \eta_c \sum_i f_i x_i$$

7.3 First-Order Taylor Expansion

Let

$$A_0 = \frac{1}{1 + e^{-L_0}}$$

$$\sigma'(L_0) = A_0(1 - A_0)$$

Then

$$A(L) \approx A_0 + A_0(1 - A_0)(L - L_0)$$

7.4 Substitute L

$$A(x, p) = A_0 + A_0(1 - A_0)\left[\tilde{\eta}_0 - L_0 - \eta_p p - \eta_c \sum_i f_i x_i\right]$$

7.5 Linearized Coefficients

Constant term:

$$\alpha_0 = A_0 + A_0(1 - A_0)(\tilde{\eta}_0 - L_0)$$

Premium coefficient:

$$\alpha_p = -A_0(1 - A_0)\,\eta_p$$

Control coefficients:

$$\alpha_i = -A_0(1 - A_0)\,\eta_c f_i$$

7.6 Final Linearized Acceptance

$$A(x,p) = \alpha_0 + \alpha_p p + \sum_i \alpha_i x_i$$

2.21 Final Profit Function

8.1 Original Expected Profit

$$E[Profit](x,p) = A(x,p)\left[p - \sum_i \kappa_i x_i - E[Payout](x)\right]$$

Recall:

$$A(x,p) = \alpha_0 + \alpha_p p + \sum_i \alpha_i x_i$$

$$E[Payout](x) = E_0 + \sum_i E_i x_i + \sum_{i<j} E_{ij} x_i x_j$$

8.2 Rewrite the Inner Bracket

$$B(x,p) = p - \sum_i \kappa_i x_i - E_0 - \sum_i E_i x_i - \sum_{i<j} E_{ij} x_i x_j$$

$$= p - E_0 - \sum_i (\kappa_i + E_i) x_i - \sum_{i<j} E_{ij} x_i x_j$$

8.3 Full Multiplication and Quadratic Truncation

$$E[Profit](x,p) = (\alpha_0 + \alpha_p p + \sum_i \alpha_i x_i) \cdot B(x,p)$$

After expansion and removal of cubic terms:

$$E[Profit](x,p) = C + C_p p + C_{pp} p^2 + \sum_i C_i x_i + \sum_i C_{ip} x_i p + \sum_{i<j} C_{ij} x_i x_j$$

8.4 Coefficient Definitions

Constant term:

$$C = -\alpha_0 E_0$$

Premium linear term:

$$C_p = \alpha_0 - \alpha_p E_0$$

Premium quadratic term:

$$C_{pp} = \alpha_p$$

Linear control terms:

$$C_i = -\alpha_0(\kappa_i + E_i) - E_0\alpha_i - \alpha_i(\kappa_i + E_i)$$

Control–premium interaction terms:

$$C_{ip} = \alpha_i - \alpha_p(\kappa_i + E_i)$$

Control interaction terms:

$$C_{ij} = -\alpha_0 E_{ij} - \alpha_i(\kappa_j + E_j) - \alpha_j(\kappa_i + E_i)$$

2.22 Final Quadratic Representation

The entire nonlinear insurance optimization model is reduced to the quadratic form:

$$E[Profit](x, p) = C + C_p p + C_{pp} p^2 + \sum_i C_i x_i + \sum_i C_{ip} x_i p + \sum_{i<j} C_{ij} x_i x_j$$

This expression is:

- Quadratic in the binary control variables x_i,
- Quadratic in the continuous premium p,
- Free of cubic or higher-order terms.

It is therefore suitable for:

- Discretization of p into binary variables,
- Construction of a QUBO matrix,
- Implementation via QAOA or quantum annealing.

2.23 Calibration of Structural Parameters

This section specifies economically coherent values for the structural parameters that are *not* part of the dataset. These parameters define the functional shape of the ransomware risk model, the insurance payout mechanism, and the acceptance (demand) model. They remain fixed across optimization runs to ensure numerical stability and interpretability.

2.23.1 Baseline Ransomware Intensity

The ransomware occurrence probability is modeled as

$$\Pr_{\text{ran}}(x, Z) = 1 - \exp\left(-\lambda_{\text{eff}}(x, Z)\, \hat{A}\, \hat{E}\, [1 - S(x)]\right),$$

where $\lambda_{\text{eff}}(x, Z) = \lambda(Z)\Phi_{\text{freq}}(x)$.

We choose the baseline annual intensity parameter

$$\lambda_0 = 0.02.$$

Justification. Empirical industry studies typically report annual ransomware incident probabilities between 5% and 25% for mid-sized firms. Since the model exponent scales with $\hat{A}\hat{E}(1-S)$, λ_0 must remain small to avoid unrealistically large probabilities. A value of 0.02 ensures that, after scaling, the annual probability remains in a realistic range while preserving validity of the small-risk approximation used in the quadratic reduction.

2.23.2 Asset and Exposure Scaling

Effective assets:

$$\hat{A} = a_0 + a_1 N, \qquad a_0 = 20, \quad a_1 = 1.2.$$

Justification. Each employee typically corresponds to approximately one endpoint device. The parameter $a_1 = 1.2$ captures additional shared infrastructure. The intercept $a_0 = 20$ reflects baseline servers and core IT systems.

Effective exposure:

$$\hat{E} = e_0 + e_1 \frac{As}{100} + e_2 C + e_3 R + e_4 \min(I, I_{\max}),$$

with

$$e_0 = 0.5,\ e_1 = 1.0,\ e_2 = 0.5,\ e_3 = 0.5,\ e_4 = 0.3, \quad I_{\max} = 5.$$

Justification. The calibration ensures $\hat{E} \in [0.5, 3]$ for realistic feature ranges. Attack surface receives the strongest weight ($e_1 = 1$), while cloud dependency and remote work moderately increase exposure. Past incidents increase risk but are capped to prevent explosive scaling.

2.23.3 Security Posture Parameters

Latent posture:

$$z(x) = z_0 + \sum_i w_i x_i + \sum_{i<j} w_{ij} x_i x_j, \qquad S(x) = \sigma(z(x)).$$

We set:

$$z_0 = -1.$$

Justification. This implies a baseline security score

$$S_0 = \sigma(-1) \approx 0.27,$$

meaning that firms without required controls have low-to-moderate protection, which is consistent with empirical cybersecurity surveys.

Control effects are bounded:

$$w_i \in [0.2, 0.6], \qquad w_{ij} \in [-0.2, 0.2].$$

This prevents excessive curvature and preserves the validity of the quadratic truncation.

2.23.4 Impact Model Parameters

Baseline impact:

$$\text{Impact}_0(x, Z) = c_1 \hat{A} + \frac{\text{Rev}}{365} \left[d_0 + d_1 \hat{A}(1 - S(x)) \right] + \gamma \text{Rev}.$$

We set:

$$c_1 = 2500, \quad d_0 = 3, \quad d_1 = 0.02, \quad \gamma = 0.05.$$

Justification.

- $c_1 = 2500$: recovery costs per endpoint in ransomware cases typically range from €1,000 to €5,000.
- $d_0 = 3$: even well-prepared firms experience several days of disruption.
- $d_1 = 0.02$: downtime increases moderately with infrastructure size and weak security.
- $\gamma = 0.05$: legal and reputational costs commonly range between 2% and 10% of annual revenue.

These values generate impact magnitudes consistent with reported mid-market ransomware losses.

2.23.5 Acceptance (Demand) Model Parameters

Acceptance probability:

$$A(\theta, Z) = \frac{1}{1 + \exp\left(-\left[\eta_0 - \eta_p(p - p_{\text{comp}}) - \eta_c F(x) + \eta_u u - \eta_d d\right]\right)}.$$

We choose:

$$\eta_0 = 0.4, \quad \eta_p = 2 \times 10^{-5}, \quad \eta_c = 0.5, \quad \eta_d = 10^{-5}, \quad \eta_u = 10^{-6}.$$

Justification.

- $\eta_0 = 0.4$ implies baseline acceptance $\approx 60\%$.
- $\eta_p = 2 \times 10^{-5}$ implies that a €100,000 premium increase reduces the logit by 2 units, significantly lowering acceptance.
- $\eta_c = 0.5$ reflects meaningful sensitivity to underwriting friction.
- η_d and η_u are small, reflecting second-order effects of deductible and limit relative to price.

2.23.6 Control Effect Parameters

Frequency and severity reductions are bounded:

$$\alpha_i \in [0.05, 0.25], \qquad \beta_i \in [0.05, 0.30],$$

$$\alpha_{ij}, \beta_{ij} \in [-0.05, 0.10].$$

Justification. Controls rarely eliminate risk entirely. Values below 30% per control are realistic and prevent excessive nonlinear amplification, preserving the validity of the quadratic approximation used in the optimization model.

2.23.7 Deductible and Limit

We set:

$$d = 10{,}000, \qquad u = 1{,}000{,}000.$$

Justification. These values are consistent with mid-sized commercial cyber policies. They ensure that moderate events penetrate the deductible, while catastrophic tail losses are capped.

2.23.8 Stability Conditions

To preserve the second-order approximation validity, we enforce:

$$|\alpha_i| < 0.3, \quad |\beta_i| < 0.3, \quad |w_i| < 0.8,$$

$$\lambda_0 \hat{A}\hat{E}(1-S) < 1.$$

These bounds prevent higher-order neglected terms from dominating, ensuring numerical stability of the quadratic formulation.

2.23.9 Binary Expansion of the Premium Variable

To obtain a pure QUBO formulation, the premium p must be discretized into binary variables.

Let

$$b_m \in \{0,1\}, \qquad m = 0, \ldots, M-1,$$

be binary decision variables.

We represent the premium as:

$$p = p_{\min} + \Delta \sum_{m=0}^{M-1} 2^m b_m,$$

where Δ is a monetary scaling factor (e.g. $\Delta = 1000$).

Range of Representation. The maximum representable premium is:

$$p_{\max} = p_{\min} + \Delta \left(2^M - 1\right).$$

To cover a desired interval $[P_{\min}, P_{\max}]$, choose M such that:

$$\Delta(2^M - 1) \geq P_{\max} - P_{\min}.$$

For example, if $P_{\min} = 5000$, $P_{\max} = 60000$, and $\Delta = 1000$, then $M = 6$ is sufficient since:

$$1000(2^6 - 1) = 63{,}000.$$

2.23.10 Substitution into the Quadratic Objective

The quadratic objective contains the terms:

$$C_p p + C_{pp} p^2 + \sum_i C_{ip} x_i p.$$

Substituting the binary expansion:

$$p = p_{\min} + \Delta \sum_m 2^m b_m,$$

we obtain the following contributions.

Linear Term in p.

$$C_p p = C_p p_{\min} + C_p \Delta \sum_m 2^m b_m.$$

This generates linear coefficients:

$$C_p \Delta 2^m \, b_m.$$

Quadratic Term p^2.

$$p^2 = \left(p_{\min} + \Delta \sum_m 2^m b_m \right)^2.$$

Expanding:

$$p^2 = p_{\min}^2 + 2p_{\min}\Delta \sum_m 2^m b_m + \Delta^2 \sum_{m,n} 2^{m+n} b_m b_n.$$

Since $b_m^2 = b_m$, this becomes:

$$p^2 = p_{\min}^2 + 2p_{\min}\Delta \sum_m 2^m b_m + \Delta^2 \sum_{m<n} 2^{m+n} b_m b_n + \Delta^2 \sum_m 2^{2m} b_m.$$

Mixed Control-Premium Term.

$$C_{ip} x_i p = C_{ip} x_i p_{\min} + C_{ip} \Delta \sum_m 2^m x_i b_m.$$

This produces quadratic interactions:

$$C_{ip} \Delta 2^m \, x_i b_m.$$

2.23.11 Final QUBO Structure

Let

$$z = (x_1, \ldots, x_6, b_0, \ldots, b_{M-1})$$

be the full binary decision vector.
The objective can be written in QUBO form:

$$z^T Q z + c,$$

with:

Linear coefficients (diagonal terms):

$$Q_{b_m b_m} = C_p \Delta 2^m + C_{pp} \left(2p_{\min} \Delta 2^m + \Delta^2 2^{2m} \right),$$

$$Q_{x_i x_i} = C_i.$$

Quadratic coefficients:

$$Q_{b_m b_n} = C_{pp}\Delta^2 2^{m+n}, \qquad m < n,$$

$$Q_{x_i b_m} = C_{ip}\Delta 2^m,$$

$$Q_{x_i x_j} = C_{ij}, \qquad i < j.$$

2.23.12 Numerical Stability Considerations

Since quadratic premium terms scale as

$$\Delta^2 2^{m+n},$$

choosing too many bits M can produce very large QUBO coefficients. Selecting $\Delta = 1000$ and a moderate M (e.g. $M = 6$) keeps coefficients within numerically stable ranges for QAOA.

2.24 Complexity Analysis of the Optimization Problem

After linearization of the ransomware probability, impact, payout, and acceptance components, and after discretization of the premium variable, the final objective function takes the form of a Quadratic Unconstrained Binary Optimization (QUBO) problem:

$$\max_{z \in \{0,1\}^N} \; z^\top Q z + c,$$

where the binary decision vector is

$$z = (x_1, \ldots, x_n, b_0, \ldots, b_{M-1}).$$

Here:

- $x_i \in \{0, 1\}$ represent the cybersecurity control decisions,
- $b_m \in \{0, 1\}$ represent the binary expansion of the premium,
- n is the number of controls,
- M is the number of bits used to discretize the premium,
- $N = n + M$ is the total number of binary variables.

Size of the Search Space Since all decision variables are binary, the total number of possible configurations is

$$|\Omega| = 2^N = 2^{n+M}.$$

Therefore, the search space grows exponentially with the number of controls and with the discretization precision of the premium. Even moderate increases in n lead to a dramatic growth in the number of feasible solutions.

Number of Quadratic Terms The QUBO matrix Q has dimension $N \times N$. The quadratic terms arise from:

- Control–control interactions: $\mathcal{O}(n^2)$,
- Control–premium interactions: $\mathcal{O}(nM)$,
- Premium–premium interactions (from p^2): $\mathcal{O}(M^2)$.

Thus, in the worst case, the number of quadratic coefficients scales as

$$\mathcal{O}(n^2 + nM + M^2) = \mathcal{O}((n + M)^2) = \mathcal{O}(N^2).$$

The model therefore induces a dense quadratic structure in general.

Computational Complexity Class The final problem is a binary quadratic optimization problem. Such problems are known to be **NP-hard**, as they generalize classical NP-hard problems such as Max-Cut and Quadratic Knapsack.

Consequently:

- No polynomial-time algorithm is known for solving the problem exactly.
- The worst-case computational time of exhaustive search is $\mathcal{O}(2^N)$.

The combinatorial difficulty arises primarily from the binary control selection, while premium discretization increases dimensionality but does not change the complexity class.

Scaling Behavior

- Increasing the number of controls n:
  - Linearly increases the number of variables,
  - Quadratically increases the number of interaction terms,
  - Exponentially increases the size of the solution space.
- Increasing the premium precision M:
  - Linearly increases the number of variables,
  - Quadratically increases the number of premium-related interaction terms,
  - Doubles the solution space for each additional bit.

In practice, the dominant driver of complexity is the number of cybersecurity controls.

Interpretation The computational hardness of the problem stems from the economic interdependencies embedded in the model. Each control affects frequency, severity, payout, and acceptance probability, generating quadratic coupling terms between decisions. After premium discretization, these interactions extend to price variables as well.

As a result, the integrated cyber risk and pricing optimization problem becomes a structured but computationally challenging QUBO, motivating the use of advanced combinatorial or quantum-inspired optimization techniques.

Chapter 3

Ransomware Security Protocols by Company Size

This appendix summarizes recommended ransomware security protocols structured by company size and cybersecurity maturity level. Controls are grouped into:

- **Preventive Controls** – reduce attack probability.
- **Detection Controls** – reduce attacker dwell time.
- **Containment and Recovery Controls** – reduce operational and financial impact.

1. Small Companies – Foundational Cyber Hygiene

Small organizations should prioritize essential, high-impact baseline controls.

- **Multi-Factor Authentication (MFA)**
  Requires two-factor authentication on email, cloud services, VPN, and privileged accounts. It significantly reduces credential-based compromise.

- **Automated Patch Management**
  Ensures timely installation of operating system and software updates to mitigate exploitation of known vulnerabilities.

- **3-2-1 Backup Strategy**
  Maintains three copies of data, on two different media types, with one copy stored off-site and offline. Regular restoration testing is required.

- **Strong Password Policy and Password Manager**
  Enforces long, unique passwords and centralized credential management to reduce password reuse and theft risk.

- **Basic Phishing Awareness Training**
  Provides employee education on identifying malicious emails, suspicious links, and social engineering attempts.

2. Medium Companies – Structured Security and Active Monitoring

Medium-sized organizations require formal processes and continuous infrastructure visibility.

- **Privileged Access Management (PAM)**
  Implements least-privilege principles, restricts administrative access, and enforces credential rotation and monitoring.

- **Endpoint Detection and Response (EDR)**
  Deploys behavioral-based endpoint monitoring capable of detecting, isolating, and responding to advanced malware.

- **Network Segmentation**
  Separates network zones (e.g., users, servers, production systems) to prevent lateral movement after compromise.

- **Security Information and Event Management (SIEM)**
  Centralizes log collection and enables event correlation, alerting, and forensic analysis.

- **Incident Response Plan (IRP)**
  Establishes documented procedures, escalation paths, and defined responsibilities for ransomware incidents.

3. Large Companies – Predictive Security and Governance

Large enterprises require integrated, risk-driven, and compliance-oriented cybersecurity frameworks.

- **Zero-Trust Architecture (ZTA)**
  Applies a "never trust, always verify" model with continuous authentication, micro-segmentation, and per-request access validation.

- **24/7 Security Operations Center (SOC)**
  Provides continuous monitoring, real-time alert triage, and proactive threat hunting to reduce attacker dwell time.

- **Threat Hunting and Threat Intelligence Integration**
  Proactively searches for adversary tactics, techniques, and procedures (TTPs) using structured intelligence frameworks.

- **Advanced Disaster Recovery and Business Continuity Planning (BCP)**
  Defines Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) with regular resilience testing and simulations.

- **Cyber Risk Quantification (CRQ)**
  Translates cyber risk into financial impact metrics using formal methodologies such as FAIR to support strategic decisions.

- **Regulatory Compliance and ICT Governance**
  Ensures structured ICT risk management, resilience controls, and mandatory incident reporting aligned with sectoral regulations.

Most Authoritative References

1. **NIST Cybersecurity Framework (CSF) 2.0**
2. **CIS Controls v8**
3. **NIST SP 800-207 (Zero Trust Architecture)**
4. **ENISA Threat Landscape 2024**
5. **Verizon Data Breach Investigations Report (DBIR) 2024**

Chapter 4

Setup and Problem Formulation

4.0.1 Proof-of-Concept Instance

To validate the proposed quantum optimization framework, we implemented a simplified proof-of-concept instance of the insurance underwriting model.

The experimental configuration includes:

- Three binary security protocols, denoted by $x_1, x_2, x_3 \in \{0, 1\}$.
- A premium variable encoded using a 3-bit binary representation.

Each protocol variable represents whether a given cybersecurity control is required (1) or not required (0). The premium is discretized using three binary variables (p_1, p_2, p_3), allowing $2^3 = 8$ possible premium levels.

The full decision vector is therefore:

$$z = (x_1, x_2, x_3, p_1, p_2, p_3)$$

which produces a total search space of:

$$2^6 = 64 \quad \text{possible configurations.}$$

This reduced-size instance allows full classical verification while remaining compatible with near-term quantum hardware constraints.

4.0.2 From Expected Profit to QUBO

The economic objective of the insurer is to maximize expected profit:

$$\mathbb{E}[\text{Profit}](x, p) = A(x, p) \left[p - \sum_i \kappa_i x_i - \mathbb{E}[\text{Loss}(x)] \right],$$

where:

- $A(x, p)$ is the acceptance probability,
- κ_i is the cost of enforcing protocol i,
- $\mathbb{E}[\text{Loss}(x)]$ is the expected payout under the selected controls.

After polynomial expansion and truncation to quadratic order, the model can be written in quadratic form:

$$\mathbb{E}[\text{Profit}](z) = C + \sum_i C_i z_i + \sum_{i<j} C_{ij} z_i z_j.$$

This quadratic structure allows direct formulation as a Quadratic Unconstrained Binary Optimization (QUBO) problem.

4.0.3 Conversion to Minimization Form

Since QAOA is formulated as an energy minimization procedure, we convert the maximization problem into a minimization problem:

$$\min_{z \in \{0,1\}^6} \quad H_{\text{QUBO}}(z) = -\mathbb{E}[\text{Profit}](z).$$

The resulting Hamiltonian defines the objective function encoded into the quantum circuit.

4.1 QUBO to Ising Mapping and Energy Interpretation

4.1.1 From Binary Variables to Spin Variables

Quantum hardware natively operates in the spin representation. Therefore, the QUBO formulation must be transformed into an Ising Hamiltonian.

Binary variables

$$z_i \in \{0, 1\}$$

are mapped into spin variables

$$s_i \in \{-1, +1\}$$

using the affine transformation:

$$z_i = \frac{1 - s_i}{2}.$$

Substituting this relation into the QUBO objective yields an equivalent quadratic function in spin variables.

4.1.2 Ising Hamiltonian Form

After substitution and coefficient collection, the objective takes the form:

$$H_{\text{Ising}}(s) = \sum_i h_i s_i + \sum_{i<j} J_{ij} s_i s_j + C_0,$$

where:

- h_i are local field coefficients,
- J_{ij} are pairwise coupling coefficients,
- C_0 is a constant energy shift.

The corresponding quantum operator representation is:

$$\hat{H}_C = \sum_i h_i Z_i + \sum_{i<j} J_{ij} Z_i Z_j + C_0 I,$$

where Z_i denotes the Pauli-Z operator acting on qubit i.

4.1.3 Role of the Constant Shift

A crucial observation concerns the constant term C_0.

The transformation from QUBO to Ising introduces constant contributions due to:

- Linear-to-quadratic coefficient redistribution,
- The affine mapping $z_i = (1 - s_i)/2$,
- Expansion of quadratic cross-terms.

Importantly:

$$\arg\min H_{\text{QUBO}}(z) = \arg\min H_{\text{Ising}}(s),$$

because constant shifts do not affect the location of the minimum.

However, constant shifts do affect the numerical value of the measured energy:

$$\langle \hat{H}_C \rangle = \langle H_{\text{QUBO}} \rangle + C_0.$$

This explains why the energy returned by QAOA does not numerically coincide with the expected profit.

4.1.4 Implication for Economic Interpretation

The Ising Hamiltonian encodes the optimization structure of the profit function, but not its direct monetary value.

QAOA minimizes the operator $\hat{H}_C$, whose ground state corresponds to:

$$\min(-\mathbb{E}[\text{Profit}]).$$

Therefore:

- The optimal bitstring is economically meaningful.
- The measured energy is not directly interpretable as profit.

The economic value must be reconstructed classically from the optimal configuration.

4.2 QAOA Optimization Procedure and Measurement Output

4.2.1 Variational Structure of QAOA

The Quantum Approximate Optimization Algorithm (QAOA) is a hybrid quantum-classical algorithm designed to approximately prepare the ground state of a cost Hamiltonian.

Given the Ising Hamiltonian $\hat{H}_C$, QAOA constructs a parameterized quantum state:

$$|\psi(\boldsymbol{\gamma}, \boldsymbol{\beta})\rangle = \prod_{k=1}^{p} e^{-i\beta_k \hat{H}_M} e^{-i\gamma_k \hat{H}_C} |+\rangle^{\otimes n},$$

where:

- p is the circuit depth (number of layers),
- $\boldsymbol{\gamma} = (\gamma_1, \ldots, \gamma_p)$,
- $\boldsymbol{\beta} = (\beta_1, \ldots, \beta_p)$,
- $\hat{H}_M = \sum_i X_i$ is the mixer Hamiltonian.

The algorithm alternates between cost evolution and mixing evolution.

4.2.2 Hybrid Optimization Loop

QAOA proceeds through the following steps:

1. Initialize all qubits in the uniform superposition state:
$$|+\rangle^{\otimes n}.$$
2. Apply alternating unitary operators generated by $\hat{H}_C$ and $\hat{H}_M$.
3. Measure the expectation value:
$$\langle \hat{H}_C \rangle_{\boldsymbol{\gamma}, \boldsymbol{\beta}}.$$
4. Use a classical optimizer to update $(\boldsymbol{\gamma}, \boldsymbol{\beta})$.
5. Repeat until convergence.

The classical optimizer searches for parameters that minimize the expected energy.

4.2.3 Measurement Output

After convergence, the circuit is sampled multiple times, producing a distribution over bitstrings:

$$z \in \{0, 1\}^6.$$

The algorithm does not output a single deterministic solution. Instead, it produces:

- A probability distribution over configurations,
- An estimate of the minimum expected energy.

The most probable bitstring is typically interpreted as the approximate optimal solution.

4.2.4 Energy Versus Economic Quantity

The measured quantity is:

$$E^* = \langle \hat{H}_C \rangle.$$

Recalling that

$$\hat{H}_C = -\mathbb{E}[\text{Profit}] + C_0,$$

it follows that:

$$E^* \neq \mathbb{E}[\text{Profit}].$$

QAOA minimizes the encoded Hamiltonian, but it does not compute financial quantities directly. The quantum circuit identifies the configuration that approximately maximizes expected profit; however, the profit value itself must be computed separately.

4.3 Classical Post-Processing and Profit Reconstruction

4.3.1 Extraction of the Optimal Configuration

After convergence of the QAOA optimization loop, the quantum circuit is sampled to obtain a distribution over bitstrings:

$$z = (x_1, x_2, x_3, p_1, p_2, p_3).$$

Let

$$z^* = \arg\max_z \Pr(z)$$

denote the most frequently observed bitstring. This configuration represents the approximate minimizer of the Ising Hamiltonian and therefore the approximate maximizer of expected profit.

The quantum algorithm provides the optimal decision structure, not the associated financial metric.

4.3.2 Premium Decoding

The premium is encoded using a 3-bit binary representation. Given bits (p_1, p_2, p_3), the decoded premium value is reconstructed classically as:

$$p = p_{\min} + \Delta \sum_{k=0}^{2} 2^k p_k,$$

where:

- $p_{\min}$ is the minimum premium level,
- Δ is the discretization step size.

This mapping is external to the quantum computation.

4.3.3 Reconstruction of Expected Profit

Once (x^*, p^*) is determined, the expected profit is computed using the original economic model:

$$\mathbb{E}[\text{Profit}](x^*, p^*) = A(x^*, p^*) \left[p^* - \sum_i \kappa_i x_i^* - \mathbb{E}[\text{Loss}(x^*)] \right].$$

This evaluation is only classical and does not involve the quantum circuit.

4.3.4 Conceptual Separation of Roles

The overall procedure can be interpreted as follows:

- The quantum component solves the combinatorial optimization problem.
- The classical component evaluates the economic outcome.

QAOA identifies the decision vector that optimizes the encoded Hamiltonian. The monetary value associated with that decision must be computed outside the quantum framework.

4.3.5 Conclusion of the Proof-of-Concept

For the reduced instance with three protocols and three premium bits:

- The QUBO-to-Ising mapping was successfully implemented.
- QAOA produced a consistent optimal configuration.
- The economic profit was correctly reconstructed via classical post-processing.

This confirms the internal coherence of the framework while clarifying a key methodological point: quantum optimization provides the optimal configuration, not the direct financial output.

This concludes the description of the proof-of-concept implementation.

4.4 Results and Discussion

The framework was evaluated on a reduced proof-of-concept instance consisting of three binary security controls and a premium encoded with three bits, resulting in a total search space of $2^6 = 64$ configurations. The expected profit function was reformulated as a QUBO, mapped to an Ising Hamiltonian, and optimized using QAOA. The algorithm converged to a stable configuration, which was subsequently decoded and evaluated using the original economic formulation.

For the medium-sized technology company considered in this experiment, the reconstructed expected profit associated with the optimal configuration was negative:

$$\mathbb{E}[\text{Profit}](x^*, p^*) < 0.$$

Within the modeled assumptions, no combination of the selected controls and discretized premium levels yields a positive expected margin. The economically consistent underwriting decision is therefore to decline coverage under the current contractual structure. This result confirms that the framework operates as a decision engine rather than a pricing tool that guarantees feasibility. It correctly identifies situations in which the insurer's risk–return trade-off is unfavorable.

At the same time, the experiment must be interpreted in light of its modeling limitations. The quadratic formulation was obtained through linearization and truncation of higher-order terms, implicitly assuming a relatively moderate risk regime. In particular, extreme loss scenarios and strong nonlinear interactions between controls were not fully represented. As a consequence, the economic landscape explored by the optimizer reflects a simplified approximation of ransomware risk dynamics.

A second limitation concerns computational scale. The experiment was restricted to six qubits due to current hardware and simulation constraints. This limits both the number of security controls that can be modeled and the precision of premium discretization. Increasing the number of controls (n) or premium bits (b) expands the search space exponentially to 2^{n+b}, quickly exceeding what can be reliably executed on present NISQ devices.

Despite these constraints, the experiment serves two important purposes. First, it validates the internal consistency of the QUBO–Ising–QAOA pipeline in an economically meaningful setting. Second, it demonstrates that the framework can produce interpretable underwriting outcomes, including the identification of non-insurable profiles. Future work should address richer risk dynamics and larger problem instances to evaluate the framework under more realistic market conditions.

Chapter 5

Conclusion

This project formulated cyber underwriting under ransomware risk as a joint optimization problem combining risk assessment and pricing within a unified mathematical framework. Instead of separating frequency–severity modeling from premium determination, we integrated security control selection, payout mechanics, customer acceptance, and pricing into a single expected profit objective.

The framework demonstrates that underwriting decisions are structurally interdependent. Security controls influence both ransomware probability and impact. Premium levels affect expected margin and acceptance probability. Underwriting friction modifies demand. These components cannot be optimized independently without distorting the insurer's true economic trade-off. By embedding them into a single objective, we obtain a coherent decision structure that reflects the combined risk–pricing problem.

Through systematic linearization and second-order truncation, the nonlinear economic model was reduced to a quadratic formulation. After binary decomposition of the premium, the problem was expressed as a QUBO instance and mapped to an Ising Hamiltonian. This enabled implementation through QAOA within a reduced proof-of-concept setting.

The experimental results highlight an important outcome. For the medium-sized firm analyzed, the reconstructed expected profit associated with the optimal configuration was negative. Within the calibrated assumptions and discretized premium space, no feasible combination of controls and price produced a positive expected margin. Economically, the model therefore recommends declining coverage under the specified contract structure. This confirms that the framework operates as a decision engine rather than a pricing mechanism designed to always produce an insurable outcome.

At the same time, the conclusions must be interpreted in light of the model's approximations. The quadratic structure relies on linearization and truncation of higher-order nonlinear terms, implicitly assuming moderate risk regimes and limited interaction intensity between controls. Extreme loss scenarios and strong nonlinear dependencies are not fully represented. As a result, the optimization landscape reflects a controlled approximation of ransomware dynamics rather than a complete actuarial model.

A second limitation concerns computational scale. The proof-of-concept instance was restricted to three controls and three premium bits, yielding a six-qubit problem. While this allowed validation of the QUBO–Ising–QAOA pipeline, it significantly constrains the richness of the decision space. Increasing the number of controls or premium precision leads to exponential growth in complexity, exceeding the capacity of current NISQ devices.

Despite these limitations, the project establishes a coherent methodological contribution. It shows that ransomware underwriting can be rigorously cast as a structured combinatorial optimization problem in which risk modeling and pricing are jointly determined. The framework

does not eliminate uncertainty, nor does it guarantee profitability, but it provides a transparent computational mechanism to evaluate insurability under explicit economic assumptions.

Future extensions should address richer severity dynamics, alternative loss distributions beyond small-risk approximations, larger control sets, and more realistic demand calibration. Scaling beyond proof-of-concept quantum instances will be necessary to assess the framework under realistic market conditions.